

individual components are used to quantify the overall effectiveness of the institution's IT risk management practices and condition. Examiners evaluate the functions identified within each component to assess the institution's ability to identify, measure, monitor, and control IT risks. The overall performance of IT within a financial institution or TSP is reflected by a composite rating. Please refer to Appendix A for additional information on composite and component URSIT ratings.

Frequency of Examinations

All TSPs that the Agencies supervise receive an examination sufficient in scope to assign or update the URSIT during each examination cycle. The number and frequency of supervisory activities conducted during the examination cycle varies depending on the risk profile of the TSP as established by the RB-EPRP and the URSIT. TSPs with a higher risk ranking are subject to more frequent and extensive examinations. The examination cycles, based on the assigned URSIT and Examination Priority Ranking (EPR), are as follows:

- **"A" ranking:** 24-month examination cycle
- **"B" ranking:** 36-month examination cycle
- **"C" ranking:** 48-month examination cycle

As part of the supervision of a TSP, examiners can conduct interim supervisory reviews or unscheduled site or service examinations for areas of evolving supervisory interest or concern. The number and frequency of interim supervisory reviews conducted during an examination cycle are based on the level of risk identified by the CPC team. All examined TSPs must receive at least one interim supervisory review during each examination cycle.

Examinations are conducted jointly according to schedules agreed upon by the participating Agencies. When joint examinations cannot be scheduled, one or more Agencies may be designated to perform the examination on behalf of all interested Agencies. If, however, the TSP's overall condition is determined to be less than satisfactory, the Agencies make a special effort to ensure subsequent examinations are conducted on a joint basis until the TSP's overall condition is satisfactory.

Risks Associated With TSPs

Operational risk is the primary risk associated with TSP processing. Operational risk may arise from inadequate or failed internal processes or systems, the misconduct or errors of people, and adverse external events. Operational risk also may affect other risks, such as credit, interest rate, liquidity, price, compliance, strategic or reputation. Other risks associated with TSPs include:

- **Reputation risk.** Errors, delays, or omissions in IT that become public knowledge or directly affect customers can significantly affect the reputation of the serviced financial institutions. For example, a TSP's failure to maintain adequate business resumption plans and facilities for key processes may impair the ability of serviced financial institutions to provide critical services to their customers.
- **Strategic risk.** Inaccurate information from TSPs can cause the management of serviced financial institutions to make poor strategic decisions.
- **Compliance (legal) risk.** Inaccurate or untimely data related to consumer compliance disclosures or unauthorized disclosure of confidential customer information could expose financial institutions to civil money penalties or litigation. For example, TSPs often agree to keep disclosures or calculations in compliance with banking regulations, and their failure to track regulatory changes could increase compliance risk for their serviced financial institutions.
- **Credit, interest rate, liquidity, and price (market) risks.** Processing errors related to investment income or repayment assumptions could increase these risks of serviced financial institutions.

The quantity of operational risk at a TSP is the level or volume of risk that exists. The quality of operational risk management is an assessment of how well risks are identified, measured, controlled, and monitored.

Risk Management

The Agencies recognize that management practices, particularly as they relate to risk management, vary considerably among financial institutions and TSPs, depending on their size and sophistication, the nature and complexity of their business activities, and their risk profile. Accordingly, the Agencies also recognize that for less complex information systems environments, detailed or highly formalized systems and controls may not be required.

Financial institutions should oversee their TSPs and perform due diligence in selecting their third-party servicers, including a review of the risk management systems used by the TSPs. Such reviews should include measures taken by the TSPs to protect information about financial institutions' customers. Financial institutions also should monitor their TSPs to confirm the TSPs implement adequate security measures. As part of their monitoring activities, financial institutions should review such information as TSP service-level reports, audits, third-party reviews, internal control testing results, and other equivalent evaluations of their TSPs.

If a TSP has weak risk management controls requiring corrective action, the TSP's serviced institutions may also have to take remedial actions because the institutions have the ultimate responsibility to properly manage their risks. Management of TSPs and financial institutions should monitor changes in laws, regulations, and guidance that affects the services provided to financial institutions.

Audit and Internal Controls

Well-planned, properly structured audit programs are essential to strong risk management and effective internal control systems. Effective internal and external audit programs are also a critical defense against fraud and provide vital information to the board of directors about the effectiveness of internal controls systems. The Agencies encourage the use of well-supported risk-based auditing. Through this process, the board, management, and auditors can focus their resources on areas of greatest risk.

TSPs with effective risk-based auditing programs typically require less examination work by the Agencies. Additional guidance on what examiners review in information systems, audit, and internal control functions can be found in the "Audit" and "Management" booklets of the IT Handbook.

Report of Examination

The Agencies have a uniform Report of Examination (ROE) format for IT examinations of financial institutions and their TSPs. The ROE includes an "Open Section," which contains all significant findings and conclusions, and a "Confidential Section," which includes information solely for the Agencies' internal use.

ROE Distribution

The ROE is generally distributed to three primary groups: the Agencies, the supervised TSP, and the serviced financial institutions.^[13]

All ROEs of a TSP, including those of stand-alone, subsidiary data centers, are directed to the board of directors, a committee thereof, or senior management of the TSP. The ROE is accompanied by a letter to the board, which includes the assigned URSIT and a reminder to recipients of the confidential nature of the letter and ROE.

The Agencies distribute to serviced financial institutions, either automatically or upon request, the Open section of a TSP ROE. Reports are automatically distributed when the TSP receives a composite URSIT rating of 4 or 5. A serviced financial institution can request a copy of the ROE from the institution's primary regulator and must demonstrate that it had a valid and current contract with the TSP as of the date of the examination.

The ROE is the joint property of the Agencies and is provided to the TSP and its client regulated financial institutions for their internal, confidential use. Under no circumstances shall any recipient of the ROE disclose or make public the ROE or any portion thereof. Unauthorized disclosure of any of the contents of the ROE is subject to the penalties in 18 USC 641.

Customer List

As part of the supervisory process, the Lead CPC obtains from the TSPs a list of

regulated financial institutions with which the servicer has entered into a contractual arrangement. The customer list, which is to be provided upon request (generally, during examinations, or, at a minimum, once each examination cycle), must be accurate, complete, and in a specified format that identifies the services being provided to each client financial institution.

The customer lists allow the Agencies to identify and validate regulated financial institutions that are entitled to copies of the ROEs produced on the TSPs. Additionally, the customer lists give the Agencies information to determine the scope of regulated financial institutions that may be affected by the operations of a TSP.

Endnotes

- | | |
|------|--|
| [1] | 12 USC 1464(d)(7), 1867(c)(1). The Consumer Financial Protection Bureau (CFPB) has authority as described in 12 USC 5514(e), 5515(d), and 5516(e). See CFPB Bulletin 2012-03 (Apr. 13, 2012), available at http://files.consumerfinance.gov/f/201204_cfpb_bulletin_service-providers.pdf . The National Credit Union Administration (NCUA) does not have independent regulatory authority over TSPs. The Agencies coordinate the interagency programs to supervise third-party servicers through the Federal Financial Institutions Examination Council (FFIEC). |
| [2] | The FFIEC was established on March 10, 1979, pursuant to Title X of the Financial Institutions Regulatory and Interest Rate Control Act of 1978 (FIRA), Public Law 95-630. The FFIEC members include the FRS, the FDIC, the NCUA, the OCC, the State Liaison Committee (SLC), and the CFPB. |
| [3] | The term TSP generally includes independent third parties, joint venture/limited liability corporations, and bank and credit union service corporations that provide processing services to financial institutions supervised by the FFIEC member Agencies. |
| [4] | Additional information on appropriate due diligence and oversight of outsourced technology services and third-party relationships can be found in the FFIEC Information Technology Examination Handbook, (IT Handbook), "Outsourcing Technology Services" booklet. |
| [5] | For example, national banks, state member banks, state non-member banks. |
| [6] | As defined in 12 U.S.C. 1861(b)(2). |
| [7] | 12 U.S.C. 1861(b)(8). |
| [8] | The examination cycle is based on the assigned Examination Priority Ranking derived through the RB-EPRP. Examination cycles are 24, 36, or 48 months. |
| [9] | An application or system is mission-critical if it is vital to the successful continuance of a core business activity. An application also may be mission-critical if it interfaces with a designated mission-critical system. Products of software vendors also may be mission-critical. |
| [10] | The FFIEC TFOS coordinates and oversees matters relating to safety and soundness supervision and examination of depository institutions. It provides a forum for the member agencies that supervise banks, thrifts, and credit unions to promote quality, consistency, and effectiveness in examination and supervisory practices and to reduce unnecessary regulatory burden on those institutions. The TFOS has one standing subcommittee, the Information Technology (IT) Subcommittee. |
| [11] | Agencies that do not have sufficient regulatory interest in a TSP may choose not to have a designated CPC. |

[12]	This list is representative of some types of service providers that may be examined and is not intended to be all-inclusive.
------	--

[13]	The Agencies also provide CFPB with access to service provider examination reports in accordance with the provisions of section 1022(c)(6)(B)(i) of the Dodd-Frank Wall Street Reform and Consumer Protection Act. See 12 USC 5512(c)(6)(B)(i)
------	--

Appendix A: URSIT

Introduction

Use of Composite Ratings

Each TSP examined for IT is assigned a summary or composite rating based on the overall results of the evaluation. The IT composite rating and each component rating are based on a scale of 1 through 5 in ascending order of supervisory concern, with 1 representing the highest rating and least degree of concern; and 5, the lowest rating and highest degree of concern.

The first step in developing an IT composite rating for an organization is the assignment of a performance rating to the individual Audit, Management, Development and Acquisition, and Support and Delivery (AMDS) components. The evaluation of each of these components, their interrelationships, and relative importance is the basis for the composite rating. A direct relationship exists between the composite rating and the individual AMDS component performance ratings. However, the composite rating is not an arithmetic average of the individual components. An arithmetic approach does not reflect the actual condition of IT when using a risk-focused approach. A poor rating in one component may heavily influence the overall composite rating for an institution.

A principal purpose of the composite rating is to identify those financial institutions and TSPs that pose an inordinate amount of information technology risk and merit special supervisory attention. Thus, individual risk exposures that more explicitly affect the viability of the organization or its customers should be given more weight in the composite rating.

The AIC of the TSP examination should notify other FFIEC Agencies' supervisory offices prior to issuing URSIT composite ratings of 3, 4, or 5 or engaging in informal or formal enforcement actions.

Use of Component Ratings

Each performance or component rating also ranges from 1 through 5, with 1 representing the highest or best, and 5, the lowest rating or worst. Each functional area of activity (audit, management, development and acquisition, and support and delivery) must be evaluated to determine its individual performance rating.

Composite Ratings Definitions

Composite - 1

Financial institutions and service providers rated composite 1 exhibit strong performance in every respect and generally have components rated 1 or 2. Weaknesses in IT are minor in nature and are easily corrected during the normal course of business. Risk management processes provide a comprehensive program to identify and monitor risk relative to the size, complexity, and risk profile of the entity. Strategic plans are well defined and fully integrated throughout the organization. This allows management to quickly adapt to changing market, business, and technology needs of the entity. Management identifies weaknesses promptly and takes appropriate corrective action to resolve audit and regulatory concerns. The financial condition of the service provider is strong and overall performance shows no cause for supervisory concern.

Composite - 2

Financial institutions and service providers rated composite 2 exhibit safe and sound performance but may demonstrate modest weaknesses in operating performance, monitoring, management processes, or system development. Generally, senior management corrects weaknesses in the normal course of business. Risk management processes adequately identify and monitor risk relative to the size, complexity, and risk profile of the entity. Strategic plans are defined but may require clarification, better coordination, or improved communication throughout the organization. As a result, management anticipates, but responds less quickly, to changes in market, business, and technological needs of the entity. Management normally identifies weaknesses and takes appropriate corrective action. However, greater reliance is placed on audit and regulatory intervention to identify and resolve concerns. The financial condition of the service provider is acceptable and while internal control weaknesses may exist, there are no significant supervisory concerns. As a result, supervisory action is informal and limited.

Composite - 3

Financial institutions and service providers rated composite 3 exhibits some degree of supervisory concern due to a combination of weaknesses that may range from moderate to severe. If weaknesses persist, further deterioration in the condition and performance of the institution or service provider is likely. Risk management processes may not effectively identify risks and may not be appropriate for the size, complexity, or risk profile of the entity. Strategic plans are vaguely defined and may not provide adequate direction for IT initiatives. As a result, management often has difficulty responding to changes in business, market, and technological needs of the entity. Self-assessment practices are weak and are generally reactive to audit and regulatory exceptions. Repeat concerns may exist indicating that management may lack the ability or willingness to resolve concerns. The financial condition of the service provider may be weak and/or negative trends may be evident. While financial or operational failure is unlikely, increased supervision is necessary. Formal or informal supervisory action may be necessary to secure corrective action.

Composite - 4

Financial institutions and service providers rated composite 4 operate in an unsafe and unsound environment that may impair the future viability of the entity. Operating weaknesses are indicative of serious managerial deficiencies. Risk management processes inadequately identify and monitor risk, and practices are not appropriate given the size, complexity, and risk profile of the entity. Strategic plans are poorly defined and not coordinated or communicated throughout the organization. As a result, management and the board are not committed to, or may be incapable of ensuring, that technological needs are met. Management does not perform self-assessments and demonstrates an inability or unwillingness to correct audit and regulatory concerns. The financial condition of the service provider is severely impaired or deteriorating. Failure of the financial institution or service provider may be likely unless IT problems are remedied. Close supervisory attention is necessary and, in most cases, formal enforcement action is warranted.

Composite - 5

Financial institutions and service providers rated composite 5 exhibit critically deficient operating performances and are in need of immediate remedial action. Operational problems and serious weaknesses may exist throughout the organization. Risk management processes are severely deficient and provide management little or no perception of risk relative to the size, complexity, and risk profile of the entity. Strategic plans do not exist or are ineffective, and management and the board provide little or no direction for IT initiatives. As a result, management is unaware of, or inattentive to, technological needs of the entity. Management is unwilling or incapable of correcting audit and regulatory concerns. The financial condition of the service provider is poor and failure is highly probable due to poor operating performance or financial instability. Ongoing supervisory attention is necessary.

Component Ratings Definitions

Each performance or component rating also ranges from 1 through 5, with 1 representing the highest and 5 the lowest rating. Each functional area of activity (audit, management, development and acquisition, and support and delivery) must be evaluated to determine its individual performance rating.

Each performance or component rating is described as follows:

Component 1-Strong performance: Performance that is significantly higher than average.

Component 2- Satisfactory performance: Performance that is average or slightly above and that provides adequately for the safe and sound operation of the data center.

Component 3-Less than satisfactory: Performance that exhibits some degree of supervisory concern due to a combination of weaknesses that may range from moderate to severe.

Component 4-Deficient: Performance that is in an unsafe and unsound environment that may impair the future viability of the entity.

Component 5-Critically deficient: Performance that is critically deficient and in need of immediate remedial attention. The financial condition of the service provider is poor and failure is highly probable due to poor operating performance or financial instability.

Component Rating Areas of Coverage

Audit

Financial institutions and service providers are expected to provide independent assessments of their exposure to risks and the quality of internal controls associated with the acquisition, implementation, and use of information technology. Audit practices should address the IT risk exposures throughout the institution and its service provider(s) in the areas of user and data center operations, client/server architecture, local and wide-area networks, telecommunications, information security, electronic data interchange, systems development, and contingency planning. This rating should reflect the adequacy of the organization's overall IT audit program, including the internal and external audit's abilities to detect and report significant risks to management and the board of directors on a timely basis. It should also reflect the internal and external auditor's capability to promote a safe, sound and effective operation.

The performance of audit is rated based upon an assessment of factors, such as:

- The level of independence maintained by audit and the quality of the oversight and support provided by the board of directors and management;
- The adequacy of audit's risk analysis methodology used to prioritize the allocation of audit resources and to formulate the audit schedule;
- The scope, frequency, accuracy, and timeliness of internal and external audit reports;
- The extent of audit participation in application development, acquisition, and testing, to ensure the effectiveness of internal controls and audit trails;
- The adequacy of the overall audit plan in providing appropriate coverage of IT risks;
- The auditor's adherence to codes of ethics and professional audit standards;
- The qualifications of the auditor, staff succession, and continued development through training;
- The existence of timely and formal follow-up and reporting on management's resolution of identified problems or weaknesses; and
- The quality and effectiveness of internal and external audit activity as it relates to IT controls.